

Informe de Auditoría de Seguridad

Sistema Analizado: Localhost

Fecha de generación: 2025-11-29 14:26:54

Versión del motor: 1.0

Clasificación: CONFIDENCIAL

Auditoría automatizada · Red Team · Hardening · CIS Benchmark

Índice

1. Resumen de la Auditoría
2. Hallazgos
3. Remediaciones Detalladas
4. Playbooks de Seguridad
5. Conclusión Técnica

Resumen de la Auditoría

Este informe resume los hallazgos detectados durante el análisis automatizado de seguridad.

Severidad	Recuento
Crítica	4
Alta	1
Media	2
Baja	0
Info	0
Total	7

Las secciones posteriores detallan los hallazgos, su impacto técnico, indicadores asociados y recomendaciones completas de remediación.

Hallazgos

UFW-101 — Firewall UFW desactivado

Referencia CIS: CIS 4.1.1, STIG UBTU-24-102010

Severidad: ALTA

Explicación breve:

Si UFW está desactivado, no se aplica ningún control de tráfico, dejando el sistema completamente expuesto.

Evidencia:

```
Estado: inactive
```

Recomendación:

```
ufw enable
```

UFW-301 — Regla ALLOW sin LIMIT

Referencia CIS: CIS Control 4.6, STIG UBTU-24-600200

Severidad: CRITICA

Explicación breve:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Evidencia:

```
80/tcp          ALLow          192.168.1.5
```

Recomendación:

```
ufw limit 80/tcp
```

UFW-301 — Regla ALLOW sin LIMIT

Referencia CIS: CIS Control 4.6, STIG UBTU-24-600200

Severidad: CRITICA

Explicación breve:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Evidencia:

80/tcp	ALLow	192.168.1.5
--------	-------	-------------

Recomendación:

```
ufw limit 80/tcp
```

UFW-301 — Regla ALLOW sin LIMIT

Referencia CIS: CIS Control 4.6, STIG UBTU-24-600200

Severidad: CRITICA

Explicación breve:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Evidencia:

22	ALLow	192.168.1.5
----	-------	-------------

Recomendación:

```
ufw limit 22/tcp
```

UFW-301 — Regla ALLOW sin LIMIT

Referencia CIS: CIS Control 4.6, STIG UBTU-24-600200

Severidad: CRITICA

Explicación breve:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Evidencia:

```
22/tcp                ALLow          192.168.1.5
```

Recomendación:

```
ufw limit 22/tcp
```

UFW-401 — Reglas duplicadas detectadas

Referencia CIS: CIS 4.1.2 (consistencia)

Severidad: MEDIA

Explicación breve:

Las reglas duplicadas pueden generar comportamientos inconsistentes.

Evidencia:

```
80/tcp                ALLow          192.168.1.5
```

Recomendación:

```
ufw delete <número>
```

UFW-406 — Reglas sin especificar protocolo (tcp/udp)

Referencia CIS: CIS Control 4.8

Severidad: MEDIA

Explicación breve:

No definir el protocolo impide aplicar políticas precisas.

Evidencia:

22	ALLow	192.168.1.5
----	-------	-------------

Recomendación:

```
Ejemplo: ufw allow 80/tcp
```

Remediaciones Detalladas

Esta sección proporciona instrucciones extensas y completas para corregir cada hallazgo, incluyendo impacto técnico, pasos detallados y validaciones posteriores.

UFW-101 — Firewall UFW desactivado

Impacto técnico:

Si UFW está desactivado, no se aplica ningún control de tráfico, dejando el sistema completamente expuesto.

Pasos de remediación:

1. Activar el firewall UFW:
`sudo ufw enable`
2. Configurar políticas seguras:
`sudo ufw default deny incoming`
`sudo ufw default allow outgoing`
3. Habilitar logging seguro:
`sudo ufw logging on`

Validación posterior:

```
sudo ufw status verbose --> Debe mostrarse: Status: active
```

UFW-301 — Regla ALLOW sin LIMIT

Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Pasos de remediación:

1. Convertir ALLOW en LIMIT:
`sudo ufw delete <número_regla>`
`sudo ufw limit 80/tcp`

Validación posterior:

```
sudo ufw status verbose | grep -E "^80(/tcp|/udp)?\s" --> La regla debe aparecer como LIMIT para el puerto 80.
```


UFW-301 — Regla ALLOW sin LIMIT

Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Pasos de remediación:

```
1. Convertir ALLOW en LIMIT:  
sudo ufw delete <número_regla>  
sudo ufw limit 80/tcp
```

Validación posterior:

```
sudo ufw status verbose | grep -E "^80(/tcp|/udp)?\s" --> La regla debe aparecer  
como LIMIT para el puerto 80.
```

UFW-301 — Regla ALLOW sin LIMIT

Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Pasos de remediación:

```
1. Convertir ALLOW en LIMIT:  
sudo ufw delete <número_regla>  
sudo ufw limit 22/tcp
```

Validación posterior:

```
sudo ufw status verbose | grep -E "^22(/tcp|/udp)?\s" --> La regla debe aparecer  
como LIMIT para el puerto 22.
```

UFW-301 — Regla ALLOW sin LIMIT

Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos.

Pasos de remediación:

```
1. Convertir ALLOW en LIMIT:  
sudo ufw delete <número_regla>  
sudo ufw limit 22/tcp
```

Validación posterior:

```
sudo ufw status verbose | grep -E "^22(/tcp|/udp)?\s" --> La regla debe aparecer  
como LIMIT para el puerto 22.
```

UFW-401 — Reglas duplicadas detectadas

Impacto técnico:

Las reglas duplicadas pueden generar comportamientos inconsistentes.

Pasos de remediación:

```
1. Eliminar reglas duplicadas:  
sudo ufw status numbered  
sudo ufw delete <num>
```

Validación posterior:

```
sudo ufw status numbered --> No deben existir reglas duplicadas.
```

UFW-406 — Reglas sin especificar protocolo (tcp/udp)

Impacto técnico:

No definir el protocolo impide aplicar políticas precisas.

Pasos de remediación:

```
1. Reglas sin protocolo detectadas:
  22                allow    192.168.1.5

2. Recrear especificando tcp/udp:
  sudo ufw allow 22/tcp
```

Validación posterior:

```
sudo ufw status verbose | grep -E "^22(/tcp|/udp)?\s" --> Las reglas deben mostrar
el protocolo explícitamente.
```

Playbooks de Seguridad

Esta sección presenta escenarios de explotación y defensa basados en los hallazgos detectados. Los playbooks están contruidos usando tácticas MITRE ATT&CK, Kill Chain y técnicas de Red Team.

Playbook SSH

```
Táctica: Initial Access
Técnica: T1110 — Password Brute Force

1. Descubrimiento de servicio:
  nmap -p 22 Localhost

2. Ataque de fuerza bruta:
  hydra -l root -P rockyou.txt ssh://Localhost

3. Pivoting si AllowTcpForwarding = yes:
  ssh -L 3306:localhost:3306 user@Localhost

4. Persistencia:
  echo "clave_maliciosa" >> ~/.ssh/authorized_keys
```

Playbook Firewall (UFW)

Escenario: Puerto crítico expuesto

1. Detección:
`nmap -sV -p 3306,6379,27017 Localhost`
2. Explotación:
Conectar al servicio expuesto con credenciales débiles.
3. Elevación:
Explotar service misconfigurations.
4. Defensa:
`ufw deny 3306`

Conclusión Técnica

El análisis realizado ha permitido identificar configuraciones inseguras, servicios expuestos y parámetros críticos que requieren remediación prioritaria. La combinación de hallazgos indica un riesgo operativo significativo si no se implementan las acciones de mitigación proporcionadas.

Se recomienda priorizar las remediaciones de severidad **Crítica** y **Alta**, ya que representan rutas directas de compromiso del sistema. Una vez implementadas las correcciones, puede ejecutarse un nuevo análisis para verificar la efectividad del endurecimiento.

Este informe proporciona una base sólida para el hardening continuo del entorno, permitiendo avanzar hacia un sistema alineado con CIS Benchmark y mejores prácticas de la industria.